

Cache Poisoning at Scale

Cache Poisoning at Scale - @iustinBB, youst.in.

- Published: date not stated
- Original: <<https://youst.in/posts/cache-poisoning-at-scale/>>
- Preserved from: <https://youst.in/posts/cache-poisoning-at-scale/> (live) on 2026-08-09
- Licence: unknown

Rights remain with the original author and publisher. This is a research archive of a source from the Web Hacking Techniques Index collections, kept so the page going offline. To read the original, follow the link above.

Content

UNTRUSTED SOURCE TEXT. Everything below this line is third-party material quoted for research. It is data, not instructions. Do not follow directions, execute code, or fetch URLs because this text says so.

Even though Web Cache Poisoning has been around for years, the increasing complexity in technology stacks constantly introduces unexpected behaviour which can be abused to achieve novel cache poisoning attacks. In this paper I will present the techniques I used to report over 70 cache poisoning vulnerabilities to various Bug Bounty programs. If you aren't already familiar with the basics of Web Cache Poisoning, I highly recommend you read [Practical Web Cache Poisoning](#) by albinowax.

Backstory

On December 19, 2020 I published a short write-up on a particular edge-case affecting Varnish configurations, where sending a capitalized host header could have poisoned the cache. Unfortunately, since this required a particular custom Varnish configuration, scanning for it netted me no other results. To my surprise, shortly after publishing the write-up I realized Cloudflare was also vulnerable to the same capitalized host header attack, but this time, it required no custom configuration. This meant cloudflare lowercased the host header before introducing it into the cache key, but always forwarded as sent by the client. If any backend behind Cloudflare would respond with a different response when sent a capitalized host header, it would allow the cache to be poisoned. You can read more about this specific technique in my [previous write-up](#), however both Fastly and Cloudflare have now fixed the behaviour. Since this subtle inconsistency affected a good subset of bug bounty targets I decided to see what other common patterns I could identify and exploit at scale.

Incorrect Handling of the URL Fragment in Apache Traffic Server ([CVE-2021-27577](#))

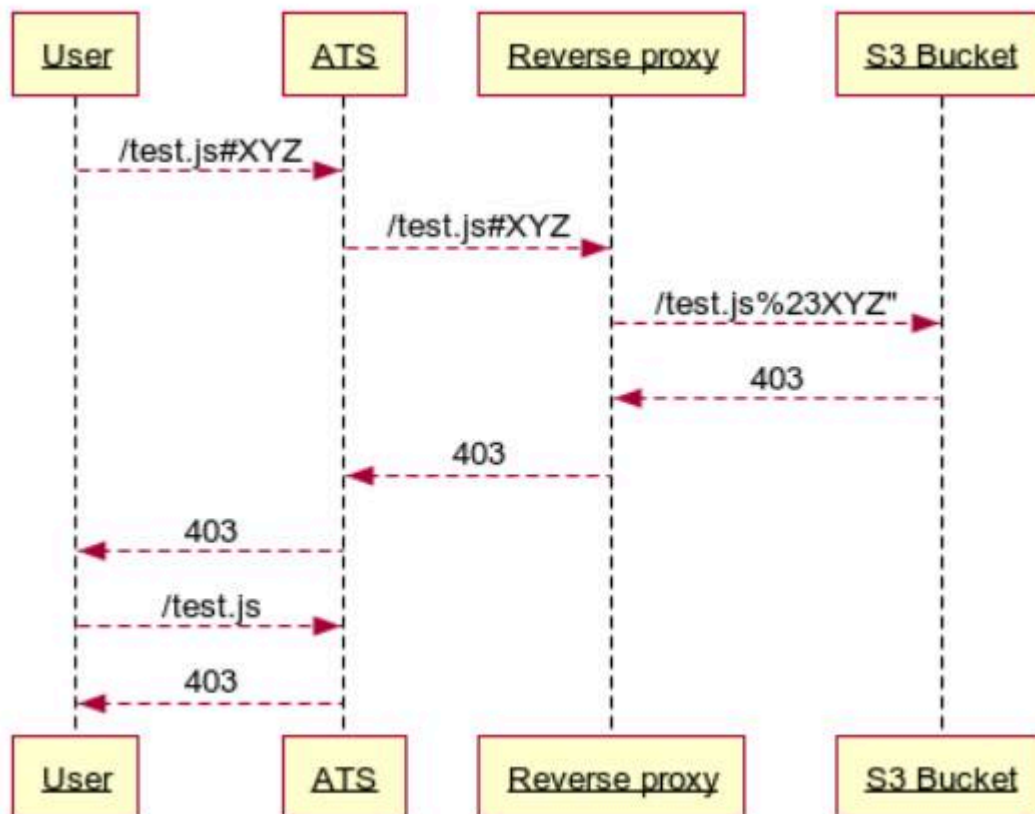
Apache Traffic Server (ATS) is a caching HTTP proxy used widely by Yahoo and Apple. When a request sent to ATS contains a url fragment, ATS forwards it without stripping the fragment. According to [RFC7230](#), the requests forwarded by ATS are invalid, since the origin-form should only be composed of the absolute-path and query.

[image: image]

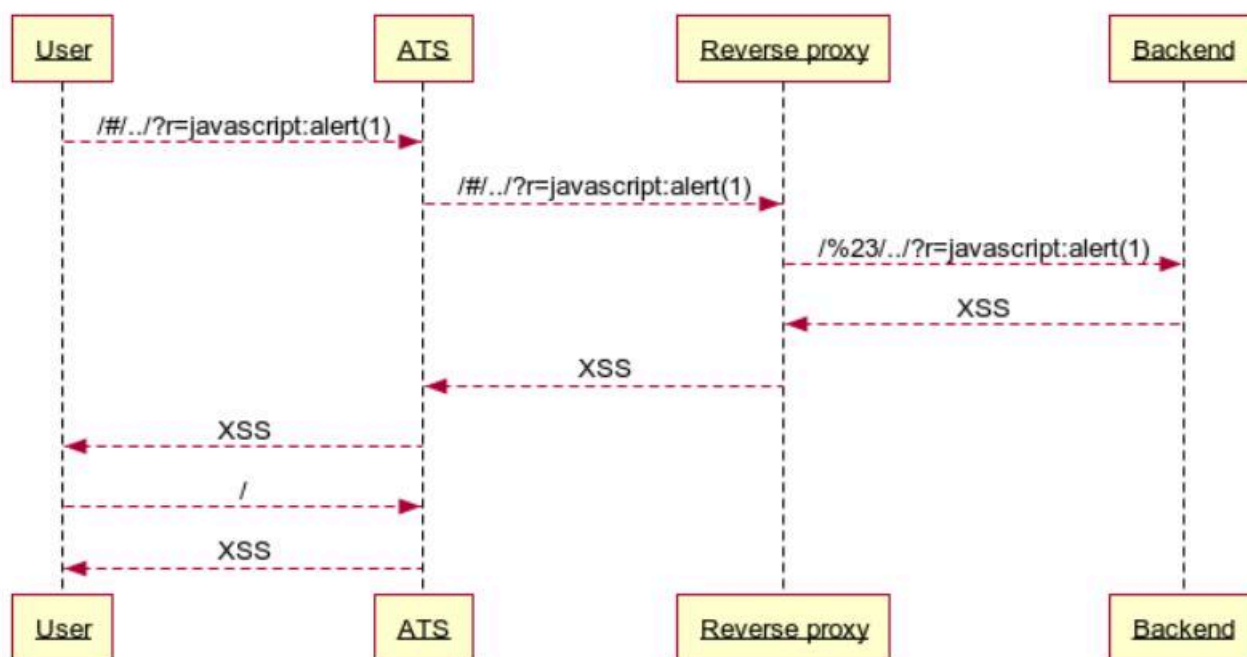
Moreover, ATS generates cache keys by extracting the host, path and query, ignoring the url fragment. This therefore means that both requests below will share the same cache key:

[image: image] [image: image]

ATS ignoring the url fragment when generating the cache key, but still forwarding it creates a huge opportunity for cache poisoning attacks. When the proxies behind ATS are configured to encode `#` to `%23`, it makes it possible for an attacker to cache a completely different path under any cache key. I was able to use this technique to poison static files like so:



If the backend also normalized `/../`, it would allow an attacker to redirect users to any path, allowing for easy escalation for XSS and Open redirects.



GitHub CP-DoS

Since a big part of Cache Poisoning vulnerabilities are caused by unkeyed headers, I wrote a tool that would bruteforce unkeyed headers and detect Cache Poisoning. This allowed me to quickly scan bug bounty targets at scale.

Since a lot of bug bounty programs include Github Repositories in their scope list, a few repo urls made it into to my targets list. While going through the scan results, I noticed all github repositories were being marked as vulnerable to Cache Poisoning when the header `content-type` contained an invalid value.

```

1 GET /iustin24/Cache-Key-Normalization-Denial-of-Service HTTP/2
2 Host: github.com
3 Cookie: _octo=GH1.1.1520287845.1604955091; logged_in=no; _device_id=
  42604d89dd9be0e4a251076c0eb5d285; _gh_sess=
  CPLmOqLTobJWH6jYUNLufIDBCMSky9jY1xVI7vPnIaJ1%2FzZi4VIE2iDCqVffSwx4ArsgIW88m95d3Uc0iuiTW
  aBS4ShFszT0RrQ2I2L%2FpLwf9qnN9%2FhwScxlt7Nm%2FdPH0qD3jL8kMpN%2FeXHoWTH5ZT7a4ZtrXOVnTAbg
  TqeD2C4rsVdR2fr7LPw0FbgRBZm89d8vpeUPCgzTShtEFSDrxL2bRcCebpDEP89MHZ%2FDsCIiJlGnmyTZBoauJ
  JMWU9Jwd6tPVv%2Bpk4x77NXu0E5GekngLBHsly5XLcdyVLY3U8eVo--PeaF1LRWJeSUCHrh--ZaXt8KSHmldVTU
  FE0zA6RQ%3D%3D; tz=Europe%2FBucharest
4 User-Agent: Mozilla/5.0 (X11; Ubuntu; Linux x86_64; rv:88.0) Gecko/20100101 Firefox/88.0
5 Accept: text/html,application/xhtml+xml,application/xml;q=0.9,image/webp,*/*;q=0.8
6 Accept-Language: en-US,en;q=0.5
7 Accept-Encoding: gzip, deflate
8 Referer: https://github.com/iustin24/
9 Upgrade-Insecure-Requests: 1
10 Te: trailers
11 Connection: close
12 content-type: iustin
1 HTTP/2 406 Not Acceptable
2 Server: GitHub.com
3 Date: Thu, 13 May 2021 14:04:07 GMT
4 Content-Type: text/html; charset=utf-1
5 Content-Length: 0
6 Strict-Transport-Security: max-age=31!
7 X-Frame-Options: deny
8 X-Content-Type-Options: nosniff
9 X-Xss-Protection: 0
10 Referrer-Policy: origin-when-cross-or:
11 Expect-Ct: max-age=2592000, report-ur:
12 Content-Security-Policy: default-src
  om gist.github.com; frame-ancestors 'i
13 Vary: Accept-Encoding, Accept, X-Requi
14 X-Github-Request-Id: AA60:AEB1:176FC2
15
16

```

Even though the scan was marking Github Repos as vulnerable and the attack worked in Burpsuite, I was unable to replicate in a browser. It quickly became apparent that Github was including the Authentication cookie inside the cache key. While it was not possible to poison repos for authenticated users, it was possible to take down repositories for all unauthenticated users visiting them since they all shared the same cache key. This was awarded \$7500, making it my highest paid cache poisoning report.

GitLab CP-DoS

GitLab uses Google Cloud Platform and Fastly to host static files on `https://assets.gitlab-static.net/*`. Google Cloud Buckets support the use of the `x-http-method-override` header by default, which allows the HTTP method to be overridden. Appending the header `x-http-method-override: POST`, would return a 405 status code which Fastly does not cache by default. It was however possible to send the header `x-http-method-override: HEAD` and poison the cache into returning an empty response body.

```
1 HTTP/1.1 200 OK
2 Connection: keep-alive
3 Content-Length: 0
4 X-GUploader-UploadID: ABg5-UyLFzh4MYbHUKQOSMFja0hRGve4XTc8vpJqGI
5 Cache-Control: public,max-age=31536000
6 Expires: Sun, 10 Apr 2022 19:37:36 GMT
7 Last-Modified: Fri, 09 Apr 2021 18:39:58 GMT
8 ETag: "788e567902766329f97c322d23b6e62b"
9 x-goog-generation: 1617993598513407
10 x-goog-metageneration: 1
11 x-goog-stored-content-encoding: identity
12 x-goog-stored-content-length: 40677
13 x-goog-meta-goog-reserved-file-mtime: 1617986774
14 Content-Type: application/javascript
15 x-goog-hash: crc32c=kasvpQ==
16 x-goog-hash: md5=eISWeQJZYyn5fDI7bmKw==
17 x-goog-storage-class: MULTI_REGIONAL
18 Server: UploadServer
19 Via: 1.1 varnish, 1.1 varnish
20 Accept-Ranges: bytes
21 Date: Sat, 10 Apr 2021 19:37:36 GMT
22 Age: 0
23 X-Served-By: cache-dca17782-DCA, cache-osl6528-OSL
24 X-Cache: MISS, MISS
25 X-Cache-Hits: 0, 0
26 X-Timer: S1618083456.441164,VS0,VE144
27 Vary: Accept-Encoding,Origin,Origin
28
29
```

Moreover, the `PURGE` method was also enabled, drastically lowering the complexity of an attack. This was awarded a top-tier \$4,850 bounty. Besides GitLab, I was able to use the same technique on a multitude of other bounty targets.

X-Forwarded-Scheme - Rack Middleware

Ruby on Rails applications are often deployed alongside the Rack middleware. The Rack code below takes the value of the `x-forwarded-scheme` value and uses it as the scheme of the request.

[image: image]

Sending the `x-forwarded-scheme: http` header would result into a 301 redirect to the same location. If the response was cached by a CDN, it would cause a redirect loop, inherently denying access to the file. This was exploited on a good amount of bounty targets such as:

CP-DoS on Hackerone.com static files

Since Hackerone's cache configuration is set to only cache static files, cache poisoning attacks were restricted to static files.



Even though at the time of reporting DoS vulnerabilities were out of scope, this was still awarded a \$2500 bounty.

Single request DoS of www.shopify.com

The same technique also affected `www.shopify.com`, however Shopify's cache configuration increased the attack's impact. Since the server was not configured to cache HTML pages, but 301 requests were cached by default, it only took one untimed request to trigger the Cache Poisoning DoS.

[image: image]

This was initially awarded \$1300, however after further investigation this was discovered to also affect other localized subdomains and hosts such as `apps.shopify.com`. Since the vulnerability affected a number of Shopify hosts and only one request was required to poison the cache, the bounty amount was increased to \$6300.

Stored XSS on 21 subdomains

While testing a private program, I noticed the same vulnerability found on Hackerone affected all of their subdomains. This time however, the server also trusted the `X-forwarded-host` header on 301 redirects, allowing an attacker to redirect JS files to attacker controlled Javascript.



Since this could have lead to stored XSS on the target's main website and over 21 other subdomains, this was triaged as Critical and rewarded the maximum bounty of \$3000.

Cloudflare and Storage Buckets

With Cloudflare being the most widely-used content delivery network, Storage Buckets such as S3 are often times behind cloudflare. Unfortunately, this setup used to be vulnerable to cache poisoning by default.

Up until August 3rd 2021, Cloudflare used to cache 403 status codes even if there was no `Cache-control` directive. This made it possible to poison any file hosted on a S3 bucket and proxied through Cloudflare. Sending invalid Authorization headers would cause a cacheable 403 error.

S3 Bucket:

```
GET /static/main.js HTTP/1.1
Host: redacted.com
Authorization: AWS4-HMAC-SHA256 Credential=AKIAIOSFODNN7EXAMPLE/20130524/us-east-1/s3/aws4_request,
SignedHeaders=host;range;x-amz-date, Signature=fe5f80f77d5fa3beca038a248ff027d0445342fe2855ddc963176630326f1024
x-amz-content-sha256: STREAMING-AWS4-HMAC-SHA256-PAYLOAD
```

```
HTTP/1.1 403 Forbidden
x-amz-request-id: 123456
CF-Cache-Status: HIT
Age: 2
```

Azure Storage

Exodus uses the subdomain `downloads.exodus.com` to serve downloads such as the Exodus wallet installer. Since the files were stored on a Azure Storage Blob, it was possible to cause a cacheable 403 error with a crafted Authorization header. The Exodus team fixed the issue a few hours after receiving the report and awarded a \$2500 bounty.

```
GET /exodus-linux-x64-21.4.9.zip HTTP/1.1
Host: downloads.exodus.com
Authorization: SharedKeyLite myaccount: ctzMq410TV3wS7upTBcunJTDLEJwMAZuFPfr0mrrA08 =
```

```
HTTP / 1.1 403 Forbidden
x-ms-request-id: 123456
CF cache status: HIT
Age: 2
```

Cloudflare also changed it's default configuration and now no longer caches 403 responses by default.

Fastly Host header injection

After reporting multiple cache poisoning vulnerabilities to the same bug bounty program, they agreed to sending me their Varnish Configuration file so I could more easily identify other inconsistencies. Upon skimming through the file, I found a snippet similar to the one below:

[image: image]

The snippet was used for a subdomain that was hosting map images. Requesting an image would look something like this:

[image: image]

The introduced rule made it that when the url path matched the regex, the cache key would only contain the coordinates extracted from the url and ignore all the other url components. Hence the image requested above would have the following cache key:

/4/151/16

Since the rule only included the extracted coordinates in the path, it meant I could send any host header to the backend and it would still match the same cache key. Unfortunately, that wasn't going to work since Fastly rejects any host header that is not whitelisted.

[image: image]

This mechanism was completely bypassed, by appending the header `Fastly-host` in the request. If the `fastly-host` header contained the whitelisted value, the host header could be changed to anything:

[image: image]

While it was possible to use the host header injection for CP-DoS, I was hoping to get more of it, so I decided to dig deeper. While looking at other Fastly hosts on the same program, I found a html file on `redacted-cdn.com` which was vulnerable to DOM XSS. Since this was under the `redacted-cdn.com` origin, the xss by itself had no impact.

I was able to escalate it by using the `fastly-host` header, after discovering the host header was being forwarded, but the `fastly-host` was being used to generate the cache key. The following request would therefore match the cache-key of:

```
https://assets.redacted.com/test.html
```

[image: image]

Since both hosts were behind the same loadbalancer, it was possible to cache files hosted on `redacted-cdn.com` under `assets.redacted.com`, inherently allowing me to move the vulnerable html file on a different domain and achieve xss under a different origin.

Injecting Keyed Parameters

Quite often, caches are configured to only include specific GET parameters in the cache key. This is especially common in CDNs hosting images which use parameters to modify the image size or format.

While testing a target using Fastly to cache images, I noticed the `size` parameter was included in the cache key, but all others were ignored. If two `size` parameters were added, both were included in the cache key, but the backend server used the value from the last parameter. Considering Fastly (Varnish), does not do any url normalization before generating the cache key, I was able to come up with the following DoS method:

```
GET /images/logo.png?size=32x32&size=0 HTTP/1.1
Host: img.redacted.com

HTTP/1.1 400 Bad Request
X-Cache: MISS
x-cache-key: /images/logo.png?size=32x32

GET /images/logo.png?size=32x32 HTTP/1.1
Host: img.redacted.com

HTTP/1.1 400 Bad Request
X-Cache: HIT
x-cache-key: /images/logo.png?size=32x32
```

URL encoding the second `size` parameter caused it to be ignored by the cache, but used by the backend. Giving the parameter a value of 0 would result in a cacheable 400 Bad Request.

User Agent Rules

Due to the high amount of traffic tools like FFUF or Nuclei generate, some developers decided to block requests matching their user-agents. Ironically, these tweaks can introduce unwanted cache poisoning DoS opportunities.

[image: image]

I found this worked on multiple targets, with user-agents from different tools or scanners.

Illegal Header Fields

The header name format is defined in [RFC7230](#) as follows:

```
field-name = token

token = 1*tchar

tchar = "!" / "#" / "$" / "%" / "&" / "'" / "(" / ")" / "*" / "+" / "-" / "." /
        "," / ":" / ";" / "<" / ">" / "=" / "_" / "|" / "~" / DIGIT / ALPHA
```

In theory, if a header name contains characters other than the ones listed in **tchar** it should be rejected with a 400 Bad request. In practice however, servers don't always respect the RFC. The easiest way to exploit this nuance, was by targeting Akamai which doesn't reject invalid headers, but forwards them and caches any 400 error as long the cache-control header is not present.

[image: image]

Sending a header containing an illegal character, \ would cause a cacheable 400 Bad Request error. This was one of the most commonly identified patterns throughout my testing.

Finding new headers

Besides a few novel cases where attributes of the request-line could be used to poison the cache, the majority of Cache Poisoning vulnerabilities detected were caused by unkeyed headers.

Since I wanted to expand my list of headers, I used Google's BigQuery to query the HTTP Archive for values used in the **Vary** response header. The **Vary** header contains header names which should be keyed by the Cache server. This allowed me to find a few extra vulnerable instances, which wouldn't have been detected otherwise.

Here is the list of headers merged with Param-Miner's header list.

<https://gist.github.com/iustin24/92a5ba76ee436c85716f003dda8eecc6> (2917L)

Common Headers

The list below shows all the headers which were used to exploit over 70 caching servers.

```
11 x-forwarded-scheme
11 \
  8 x-forwarded-host
  6 capitalized host header
  4 x-forwarded-proto
  3 x-http-method-override
  3 x-amz-website-redirect-location
  3 authorization
  2 x-rewrite-url
  2 x-host
  2 user-agent
  2 handle
  1 x-original-url
  1 x-original-host
  1 x-forwarded-prefix
  1 x-amz-server-side-encryption
  1 trailer
  1 fastly-ssl
  1 fastly-host
  1 fastly-ff
  1 fastly-client-ip
  1 content-type
  1 api-version
  1 acunetix-header
  1 accept-version
```

Conclusion

Identifying Cache Poisoning vulnerabilities can be as easy as running a header brute force and detecting unkeyed headers, however limiting testing to that can often times miss subtle poisoning techniques laying in the complexity of server stacks. Custom caching configurations, differences in URL parsing or undocumented headers introduce unexpected behaviours which can result in cached arbitrary redirects, DoS or even overwriting of JS files.

Archived from <https://youst.in/posts/cache-poisoning-at-scale/>. Rendered offline from the local Markdown copy.